

SAE — SITUATION D'APPRENTISSAGE ET D'ÉVALUATION

Réponse à incident & Continuité d'activité

BUT Informatique — Parcours Cybersécurité — Semestre 5

Champ	Information
Niveau	BUT3 — Informatique — Parcours Cybersécurité
Semestre	S5
Durée totale	25 heures (15h autonomie + 10h TD encadré)
Taille des groupes	4-5 étudiants
Livrables	1 PowerPoint direction + 1 Rapport technique RSSI/DSI
Cas de référence	CHSF Corbeil-Essonnes — Cyberattaque LockBit 3.0 (août 2022)

1 — CONTEXTE ET MISE EN SITUATION

Vous venez d'être mandatés par la direction d'un centre hospitalier régional de taille importante pour prendre en charge la réponse à une cyberattaque majeure. La nuit du samedi 20 au dimanche 21 août, à 1h du matin, un ransomware a chiffré la quasi-totalité du système d'information de l'établissement.

L'établissement touché

Centre hospitalier public — 1 068 lits et places — ~2 500 agents — 700 000 habitants couverts (Île-de-France). L'hôpital assure les urgences adultes, pédiatriques et gynécologiques, le SAMU-SMUR départemental, et une cinquantaine de spécialités médicales. Il est l'établissement de référence de son territoire.

Au matin du 21 août, le constat est le suivant :

- 90% du système d'information est chiffré et inaccessible
- Les dossiers patients, l'imagerie médicale et les logiciels de gestion sont indisponibles
- Une note de rançon réclame 10 millions de dollars
- La direction a décidé de ne pas payer la rançon
- L'ANSSI et l'ARS ont été contactées

L'enquête technique menée par l'ANSSI révèle que les attaquants étaient présents dans le SI depuis 10 jours avant de déclencher le ransomware. L'accès initial a été obtenu via le VPN, en détournant le compte d'un prestataire externe. Le groupe LockBit (russophone) revendiquera l'attaque le 12 septembre. Faute de paiement, 11 Go de données seront publiés fin septembre.

Base documentaire

Ce scénario est directement inspiré de l'attaque réelle du Centre Hospitalier Sud-Francilien (CHSF) de Corbeil-Essonnes en août 2022, l'un des incidents les plus documentés publiquement en France. Utilisez les sources listées en section 5 pour étayer vos analyses et recommandations.

2 — VOTRE MISSION

Vous intervenez en tant que groupe d'experts mandatés simultanément par la direction de l'hôpital et son RSSI. Votre mission se décompose en deux axes :

Axe 1 — Plan de Continuité d'Activité (PCA)

La direction doit prendre des décisions critiques dans les prochaines 72 heures. Elle a besoin d'une vision claire, sans jargon technique, sur :

- L'état des lieux de l'incident et ses impacts opérationnels
- Les modes de fonctionnement dégradé service par service
- Les décisions à valider en urgence (72h)
- La communication à destination des patients, du personnel, des médias et des autorités
- La projection réaliste de retour à la normale

Axe 2 — Plan de Remédiation (PRA) — volet RSSI/DSI

En parallèle, votre RSSI a besoin d'une analyse technique approfondie et d'un plan de remédiation structuré couvrant :

- La reconstitution précise de la chaîne d'attaque (5 phases ANSSI)
- L'inventaire des systèmes compromis avec leur niveau de criticité
- Les actions de remédiation urgentes (< 72h) : isolation, sauvegardes, conformité réglementaire
- Les actions de remédiation profonde (3 semaines à 18 mois) : reconstruction AD, segmentation, supervision
- Les indicateurs de pilotage du retour à la normale

3 — LIVRABLES ATTENDUS

Livrable 1 — Présentation PowerPoint « Direction »

Critère	Détail
Destinataires	Directeur Général, Président du Conseil de Surveillance, ARS
Nombre de slides	10 à 14 slides (hors diapositive de titre)
Durée de soutenance	15 minutes de présentation + 10 minutes de questions
Niveau de langage	Aucun acronyme technique non défini — zéro jargon informatique

Critère	Détail
Contenu obligatoire	État des lieux · Impacts opérationnels · PCA et modes dégradés · Décisions 72h · Communication de crise · Retour à la normale
Interdictions	Captures d'écran techniques · Schémas réseaux complexes · Termes comme « ESXi », « AD », « VLAN » non expliqués

Livrable 2 — Rapport Technique RSSI/DSI

Critère	Détail
Destinataires	RSSI, DSI, éventuellement DG pour arbitrages budgétaires
Volume	25 à 35 pages (hors annexes)
Format	Document Word ou PDF structuré avec sommaire, numérotation, sources
Contenu obligatoire	Analyse de la chaîne d'attaque · Inventaire systèmes compromis · Remédiation urgente · Remédiation profonde · Indicateurs de pilotage · Recommandations gouvernance
Références obligatoires	Minimum 4 sources documentées (ANSSI, ISO, guides sectoriels) citées en pied de page ou bibliographie
Page de contributions	Répartition explicite des tâches entre les 4 membres du groupe

Cohérence entre les deux livrables

Les deux documents doivent être cohérents. Les délais annoncés dans le PowerPoint doivent correspondre au plan de remédiation du rapport. Les décisions demandées à la direction doivent trouver leur justification technique dans le rapport. Un jury lira les deux documents simultanément.

4 — PLANNING DES 25 HEURES

Heures en autonomie (15h)

Phase	Activité principale	Durée	Production attendue
Analyse documentaire	Lecture des 5 sources, construction de la timeline d'attaque, identification des 5 phases ANSSI	3h	Fiche synthèse timeline + IoC
Cartographie d'impact	Identification des services critiques, niveaux de dépendance SI, priorisation PCA	2h	Tableau services / état / criticité
Élaboration PCA	Modes dégradés par service, procédures manuelles, communication de crise, obligations CNIL	4h	Contenu PowerPoint direction
Analyse technique	Reconstitution de la chaîne d'attaque, vecteurs, outils LockBit, référencement MITRE ATT&CK	2h	Section 2 du rapport technique
Plan de remédiation	Actions urgentes (< 72h) et profondes (3–18 mois), indicateurs de pilotage	3h	Sections 4, 5, 6 du rapport
Mise en forme finale	Cohérence des deux livrables, vérification des sources, mise en page	1h	Livrables finalisés

Heures en TD encadré (10h)

TD	Objectif	Durée	Ce que l'enseignant évaluera
TD 1 — Cadrage PCA	Corriger les erreurs de priorisation, poser le cadre ISO 22301 (RTO/RPO), arbitrer les modes dégradés, aborder la communication de crise	4h	Pertinence des choix de priorisation, compréhension des enjeux patient
TD 2 — Revue intermédiaire	Feedback sur les deux livrables en cours, alignement des recommandations techniques sur les standards, cohérence PCA/PRA	3h	Profondeur technique, qualité des références, cohérence inter-livrables
TD 3 — Soutenance direction	Simulation de comité de direction. Questions de non-techniciens. Notation finale des deux livrables.	3h	Clarté orale, robustesse des arguments, qualité des livrables

5 — SOURCES ET DOCUMENTATION FOURNIE

Les sources suivantes sont mises à votre disposition. Elles constituent votre base documentaire principale. Toute recommandation dans vos livrables doit pouvoir être référencée à l'une de ces sources ou à un standard reconnu.

Référence	Type	Contenu clé	Accès
LeMagIT — sept. 2022	Presse spécialisée	Enquête technique ANSSI — 5 phases de l'attaque — modus operandi LockBit ESXi	lemagit.fr (recherche « CHSF cyberattaque autopsie »)
HeadMind Partners — déc. 2022	RETEX détaillé	Chronologie complète, aspects juridiques, gestion de crise, enseignements	headmind.com (recherche « CHSF leçons cyberattaque »)
Banque des Territoires — oct. 2022	Actualité officielle	Chronologie remédiation, chiffres d'activité, annonces direction	banquedesterritoires.fr (recherche « CHSF cyberattaque retour normale »)
ANSSI CERTFR-2021-CTI-001	Rapport officiel	État de la menace rançongiciel — modèle RaaS — double extorsion — LockBit	cert.ssi.gouv.fr
CHSF Bilan & Perspectives 2023-2024	Rapport officiel	Impact financier, coût reconstruction (4,5 M€), chronologie longue	chsf.fr (publications institutionnelles)
MITRE ATT&CK	Base de connaissance	Tactiques et techniques LockBit — T1486, T1190, T1021.004	attack.mitre.org
ISO 22301:2019	Standard international	Management de la continuité d'activité — définitions RTO/RPO/BIA	iso.org (ou synthèses AFNOR)
ANSSI — Guide ransomwares	Guide pratique	Bonnes pratiques de prévention et réponse aux rançongiciels	cyber.gouv.fr

6 — GRILLE D'ÉVALUATION (INDICATIVE)

Livrable	Critère	Points de vigilance
PowerPoint direction (40%)	Accessibilité pour non-techniciens	Absence d'acronymes non définis, clarté du message
PowerPoint direction (40%)	Pertinence et réalisme du PCA	Priorisation crédible, modes dégradés concrets
PowerPoint direction (40%)	Gestion communication de crise	CNIL, ARS, patients, presse — délais respectés
PowerPoint direction (40%)	Qualité de la soutenance orale	Prise de parole, gestion des questions direction
Rapport technique (50%)	Exactitude de l'analyse d'attaque	5 phases ANSSI correctes, vecteurs identifiés
Rapport technique (50%)	Pertinence des remédiations	Urgences vs profond, hiérarchisation, justification
Rapport technique (50%)	Qualité des sources et références	Min. 4 sources, normes ISO/ANSSI citées
Rapport technique (50%)	Recommandations gouvernance	Réalisme, priorisées, chiffrées si possible

Livrable	Critère	Points de vigilance
Organisation groupe (10%)	Page de contributions	Répartition claire et équitable
Organisation groupe (10%)	Cohérence inter-livrables	PCA et PRA alignés sur les mêmes délais

7 — CONSEILS MÉTHODOLOGIQUES

Sur la durée réelle de remédiation

L'erreur la plus fréquente est de sous-estimer la durée. Dans le cas réel, il a fallu 2 mois pour atteindre 80% de restauration, et 12 à 18 mois pour la reconstruction complète (4,5 M€). Votre PCA doit refléter cette réalité — pas 15 jours de retour à la normale.

Sur la chaîne d'attaque

La présence de 10 jours avant le chiffrement est le point technique le plus important. Elle implique que les sauvegardes récentes PEUVENT être compromises. Ne proposez jamais « restaurer depuis les sauvegardes » sans préciser qu'elles doivent d'abord être vérifiées sur un réseau isolé.

Sur la séparation des deux livrables

Le PowerPoint direction ne doit PAS mentionner 'ESXi', 'Active Directory', 'VLAN' ou 'LockBit 3.0'. Ces termes n'ont aucune signification pour un directeur général. Traduisez toujours : 'nos serveurs virtuels ont été chiffrés', 'notre annuaire informatique est compromis', etc.

Sur les obligations réglementaires

La notification à la CNIL est une OBLIGATION légale dans les 72h suivant la détection (RGPD Art. 33). L'oublier dans votre PCA est une erreur éliminatoire. De même, la plainte pénale (Parquet de Paris, C3N) doit figurer dans les actions J+0.

ANNEXE A — ENQUÊTE TECHNIQUE ANSSI : RECONSTITUTION DE L'ATTAQUE

Cette annexe restitue les éléments rendus publics par l'ANSSI à la suite de son enquête technique sur l'attaque du CHSF. Elle constitue votre source primaire pour l'analyse de la chaîne d'attaque. Chaque phase doit être retrouvée et développée dans votre rapport technique.

Origine de ces informations

L'ANSSI a été mandatée dès J+0 pour conduire l'enquête technique sur site. Les éléments ci-dessous proviennent du rapport d'investigation technique de l'ANSSI tel que repris par LeMagIT (8 sept. 2022) et par le RETEX HeadMind Partners (déc. 2022). Ils constituent les faits établis de l'incident.

PHASE 1 — ACCÈS INITIAL | Environ J-10 (aux alentours du 10 août 2022)

Élément	Détail établi par l'enquête ANSSI
Vecteur d'accès initial	Accès VPN de l'établissement
Compte utilisé	Compte d'un tiers externe à l'établissement (prestataire), probablement compromis en amont
Machine source de l'attaquant	Machine virtuelle Windows 10 ou Server 2016, hébergée dans l'environnement cloud EC2 d'AWS
Durée de présence avant déclenchement	10 jours (du ~10 août au 21 août 2022)
Signal d'alerte manqué	Connexion VPN depuis une plage IP IaaS (AWS EC2) — aucune supervision en place

Points d'attention pour votre analyse :

- L'absence de MFA sur les accès VPN est le facteur facilitant principal : sans second facteur, la compromission du seul mot de passe suffit à obtenir un accès légitime au SI.
- La connexion depuis une IP AWS EC2 est un indicateur de compromission (IoC) détectable a posteriori. L'ANSSI recommande explicitement de surveiller les connexions VPN provenant de plages IP IaaS.
- Le compte prestataire n'est pas confirmé comme la source initiale de la compromission — il peut avoir été subtilisé par phishing, credential stuffing ou achat sur le darknet.

PHASE 2 — RECONNAISSANCE, DÉPLACEMENT LATÉRAL ET PRÉPARATION | J-10 → J-1

Outil / Action	Description technique	Référence MITRE ATT&CK
AnyDesk	Outil de prise en main à distance légitime, détourné pour les déplacements latéraux entre machines du SI	T1219 — Remote Access Software

Outil / Action	Description technique	Référence MITRE ATT&CK
PCHunter	Outil de diagnostic système (niveau kernel) utilisé pour désactiver les agents de sécurité (antivirus, EDR) sur les postes et serveurs	T1562.001 — Disable or Modify Tools
Suppression des Shadow Copies	Destruction des sauvegardes instantanées natives Windows pour empêcher toute restauration rapide	T1490 — Inhibit System Recovery
Désactivation de Windows Defender	Neutralisation de la protection native de Windows sur l'ensemble du parc	T1562.001 — Disable or Modify Tools
Exfiltration vers MEGA	Transfert des données sensibles vers le service de stockage cloud MEGA avant chiffrement (double extorsion)	T1567.002 — Exfiltration to Cloud Storage
Élévation de privilèges (AD)	Progression jusqu'aux droits Administrateur de domaine via l'Active Directory	T1078 — Valid Accounts

Points d'attention pour votre analyse :

- PCHunter est un outil dual-use (légitime pour les administrateurs, redoutable pour les attaquants) : sa présence sur un serveur de production doit déclencher une alerte immédiate dans un SIEM.
- La suppression des Shadow Copies est une action quasi-systématique dans les attaques LockBit. Elle explique pourquoi la restauration rapide est impossible et impose une reconstruction complète depuis des sauvegardes externes.
- L'exfiltration vers MEGA est le fondement de la double extorsion : même sans payer pour le déchiffrement, l'établissement reste sous pression de la publication des données.
- La durée de 10 jours de présence invisible illustre l'absence d'un SIEM/SOC capable de corrélérer les signaux faibles (connexion depuis AWS, désactivation d'outils de sécurité, transferts massifs vers MEGA).

PHASE 3 — DÉPLOIEMENT DU RANSOMWARE SUR LE PARC WINDOWS | 21 août 2022, ~01h00

Élément	Détail établi par l'enquête ANSSI
Ransomware déployé	LockBit 3.0 (alias LockBit Black) — variant Windows — en usage par la franchise depuis début mai 2022
Heure de déclenchement	1h00 du matin, nuit du samedi au dimanche — heure choisie délibérément pour minimiser la réactivité des équipes
Mécanisme	Exécution du binaire LockBit 3.0 sur les machines Windows du réseau, chiffrement de fichiers avec extension aléatoire
Résultat immédiat	Paralysie du SIH, DPI, messagerie et applications métier — note de rançon déposée sur tous les systèmes
Délai avant détection	Quelques heures (détection au matin du 21 août par l'équipe d'astreinte)

PHASE 4 — CHIFFREMENT DE L'INFRASTRUCTURE VIRTUELLE (ESXi) | 21 août 2022, ~02h30 (+1h30 après phase 3)

Élément	Détail établi par l'enquête ANSSI
Cible	Hyperviseurs VMware ESXi hébergeant l'intégralité du parc virtuel Windows
Protocole utilisé	SSH (Secure Shell) — protocole d'administration à distance des serveurs Linux/ESXi
Compte utilisé	Compte root (administrateur superutilisateur des ESXi)
Variant déployé	LockBit 3.0 — variant Linux/ESXi — chiffre directement les fichiers .vmdk (disques des machines virtuelles)
Délai entre phase 3 et phase 4	Environ 1h30 — le chiffrement Windows précède le chiffrement ESXi
Impact	Chiffrement simultané de toutes les VM hébergées — reconstruction nécessite de recréer chaque VM individuellement
Lien avec d'autres attaques	Le hash d'un des outils utilisés correspond à celui observé dans l'attaque du réseau de santé argentin OSDE (fin juin 2022)

Points d'attention pour votre analyse :

- Le ciblage des ESXi est le geste le plus dévastateur de l'attaque : une seule commande chiffre l'ensemble du parc virtuel. C'est pourquoi l'ANSSI recommande de désactiver SSH sur les ESXi en production (ou de le restreindre à des IP d'administration dédiées).
- L'accès root sur les ESXi indique que l'attaquant avait obtenu les identifiants d'administration de l'infrastructure de virtualisation — probablement via l'AD compromis ou via des mots de passe réutilisés.
- Le délai de 1h30 entre les deux phases de chiffrement est pédagogiquement important : une détection rapide du chiffrement Windows aurait pu permettre d'isoler les ESXi avant leur compromission.

PHASE 5 — DOUBLE EXTORSION ET ATTRIBUTION | Août → Septembre 2022

Date	Événement
21 août 2022	Note de rançon : 10 millions de dollars. Refus immédiat de la direction.
~25 août 2022	Échanges entre l'attaquant et un interlocuteur du CHSF — rançon ramenée à 1 million de dollars. L'attaquant semble ignorer que c'est un hôpital public (budget contraint).
12 septembre 2022	Revendication publique sur le site vitrine de LockBit 3.0 (darknet). Délai de paiement fixé au 23 septembre.
23 septembre 2022	Expiration du délai. Publication de plus de 11 Go de données sensibles (données patients, RH, données administratives).
Suite	Enquête judiciaire confiée au C3N (Centre de lutte contre les criminalités numériques) de la gendarmerie nationale. Le CHSF a diffusé un modèle de plainte aux patients et au personnel.

RÉCAPITULATIF — CHAÎNE D'ATTAQUE COMPLÈTE

Phase	Nom	Technique principale	Outil(s) ANSSI identifié(s)	MITRE ATT&CK
1	Accès initial	Connexion VPN via compte prestataire compromis (depuis AWS EC2)	VPN légitime détourné	T1133 — External Remote Services
2a	Déplacement latéral	Prise en main à distance de machines internes	AnyDesk	T1219 — Remote Access Software
2b	Évasion défensive	Désactivation des protections (AV, EDR, Defender)	PCHunter	T1562.001 — Disable/Modify Tools
2c	Destruction sauvegarde	Suppression des Shadow Copies Windows	Commandes WMI natives	T1490 — Inhibit System Recovery
2d	Exfiltration	Transfert des données vers cloud (double extorsion)	MEGA (MEGASync)	T1567.002 — Exfiltration to Cloud
3	Chiffrement Windows	Déploiement LockBit 3.0 sur le parc Windows	LockBit Black (Windows)	T1486 — Data Encrypted for Impact
4	Chiffrement ESXi	Connexion SSH root, exécution variant Linux/ESXi	LockBit 3.0 (Linux/ESXi)	T1021.004 — SSH + T1486
5	Extorsion	Publication des données sur site vitrine LockBit	Site darknet LockBit 3.0	T1657 — Financial Theft

ANNEXE B — PROFIL LOCKBIT 3.0 ET CONTEXTE SECTORIEL

B.1 Qu'est-ce que LockBit 3.0 ?

LockBit est une franchise criminelle de type Ransomware-as-a-Service (RaaS) d'origine russophone, active depuis 2019. Le modèle RaaS consiste à mettre à disposition le ransomware, son infrastructure de paiement et son support technique à des « affiliés » (affidés) qui mènent les attaques et partagent les rançons récupérées avec les développeurs.

Caractéristique	LockBit 3.0 (alias LockBit Black)
Version	LockBit 3.0 — en circulation depuis mai 2022. Fruit d'un croisement avec le code source de BlackMatter (groupe dissous).
Modèle économique	RaaS — affiliés recrutés sur forums cybercriminels, partage des rançons (typiquement 80% affilié / 20% développeurs)
Plateformes ciblées	Windows (x86/x64), Linux, VMware ESXi — le variant ESXi cible directement les fichiers .vmdk des machines virtuelles
Double extorsion	Exfiltration préalable des données + publication sur site vitrine (.onion) si refus de payer
Règles de la franchise	Interdiction théorique d'attaquer hôpitaux, établissements scolaires et services publics essentiels — règle peu respectée en pratique
Chiffrement	Combinaison AES + ECC (courbes elliptiques) — décryptage impossible sans clé privée de l'attaquant
Attribution CHSF	Un affilié de la franchise LockBit — probablement le même que celui ayant attaqué le réseau de santé OSDE (Argentine) en juin 2022

B.2 Contexte — Les hôpitaux, cibles privilégiées

Le CHSF n'est pas un cas isolé. Les établissements de santé constituent une cible de choix pour les groupes ransomware, pour trois raisons convergentes :

- **Criticité opérationnelle** : un hôpital ne peut pas s'arrêter. La pression pour payer et rétablir rapidement les systèmes est maximale — les attaquants en sont pleinement conscients.
- **Sous-investissement historique en cybersécurité** : les budgets IT des hôpitaux publics sont contraints, les équipes réduites, et les systèmes souvent vieillissants et hétérogènes.
- **Données particulièrement sensibles** : les données de santé sont les plus valorisées sur les marchés cybercriminels (revente, chantage, usurpation d'identité médicale).

Établissement	Date	Groupe	Impact principal
CH de Dax	Février 2021	Ryuk	Arrêt complet du SI — 2,3 M€ de coût de remédiation
CHU de Brest	Mars 2021	Non attribué	Déconnexion préventive du réseau — dégâts limités

Établissement	Date	Groupe	Impact principal
GHT de Cœur Grand Est	Avril 2021	Non attribué	Chiffrement partiel — fonctionnement dégradé plusieurs semaines
CH Sud-Francilien (CHSF)	Août 2022	LockBit 3.0	90% SI chiffré — 2 mois de remédiation — 4,5 M€ reconstruction
CH André-Mignot (Versailles)	Décembre 2022	Non attribué	Fermeture urgences — transfert patients — activité dégradée
CH de Cannes	Avril 2024	Lockbit 3.0	Retour au papier — dossiers patients inaccessibles plusieurs semaines

B.3 Recommandations ANSSI issues de l'enquête CHSF

À l'issue de son investigation, l'ANSSI a formulé plusieurs recommandations directement tirées du modus operandi observé. Ces recommandations doivent figurer dans votre plan de remédiation profonde.

N°	Recommandation ANSSI	Justification tirée de l'attaque CHSF
R 1	Surveiller les connexions VPN depuis des plages IP IaaS (AWS, OVH, Azure...)	L'attaquant s'est connecté depuis une VM EC2 AWS — signal détectable
R 2	Détecter la désactivation des outils de protection des endpoints	PCHunter a désactivé AV et EDR sans déclencher d'alerte
R 3	Surveiller les transferts sortants vers des services de stockage cloud	Données exfiltrées vers MEGA sans alerte de data loss prevention
R 4	Restreindre ou désactiver SSH sur les hyperviseurs ESXi en production	L'attaquant a accédé aux ESXi en root via SSH
R 5	Implémenter une authentification MFA sur tous les accès distants	Seul un mot de passe compromis a suffi pour l'accès initial
R 6	Appliquer le principe du moindre privilège sur les comptes prestataires	Le compte tiers disposait de droits suffisants pour se propager
R 7	Maintenir des sauvegardes hors ligne régulièrement testées	Les Shadow Copies (sauvegardes en ligne) ont été supprimées par l'attaquant